Day38_ApplicationMapping

Q1 — Scope [2 Marks]

Explain In-Scope and Out-of-Scope in authorized security testing.

- **In-Scope:** Systems, hosts, applications and resources that are explicitly authorized for security testing.
- **Out-of-Scope:** Systems or resources that are not included in the testing authorization. A tester must not scan, test or interact with them as testing targets.

Q2 — Burp Target Scope [2 Marks]

Explain at least three benefits of configuring Target Scope before deeper testing.

- Defines boundaries: Identifies which hosts and applications are authorized for testing.
- Reduces unrelated traffic: Helps filter requests that do not belong to the authorized target.
- Prevents accidental testing: Reduces the risk of interacting with unauthorized systems.

Q3 — Site Map [2 Marks]

What is the Burp Site Map? What types of application information can it contain?

The Burp Suite Site Map is a feature under the Target tab that displays the discovered structure of a web application.

It can contain:

- Hosts and domains.

- Directories and URL paths.

- Application endpoints and HTTP methods.

- Request parameters.

- Response information and status codes.

- Static resources such as images, CSS and JavaScript files.

It helps testers understand the structure and functionality of the application.

Q4 — HTTP History [2 Marks]

Explain the difference between Proxy HTTP History and Target Site Map.

Proxy HTTP History	**Target Site Map**
Displays captured HTTP requests and responses.	Displays the discovered structure of the target application.
Shows methods, URLs, status codes, headers and parameters.	Organizes hosts, directories, endpoints and resources.

Useful for examining individual requests.	Useful for understanding the overall application structure.

Q5 — Application Mapping [3 Marks]

Create a table containing at least 8 discovered application functions/endpoints with: Path, Method, Parameters, Authentication Requirement, Purpose.

Path	Method	Parameters	Authentication	Purpose
/	GET	None observed	No	Displays homepage
/product	GET	productId	No	Displays product details
/cart	GET	None observed	Not confirmed	Displays shopping cart
/cart	POST	productId, quantity, price, redir	Not confirmed	Submits cart information
/my-account	GET	id	Yes, appears required	Displays account information
/logout	Not confirmed	Not confirmed	Yes, expected	Logout functionality
/cart/checkout	POST	Not confirmed	Not confirmed	Processes checkout request
/cart/order-confirmation	GET	Query parameter observed; exact name not recorded	Not confirmed	Displays order confirmation

Q6 — Input Surface [2 Marks]

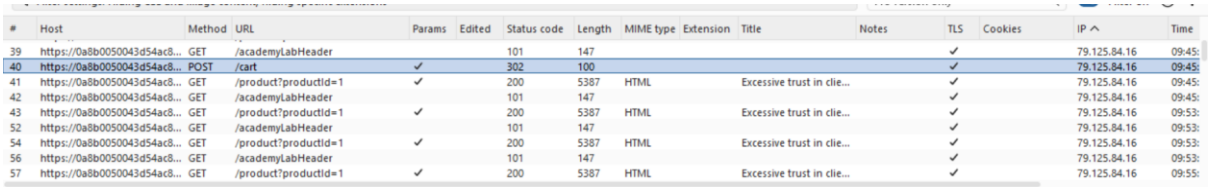
List the parameters/input points discovered during your authorized lab. Explain why inputs are important during later security testing.

Parameter	Purpose
productId	Identifies a product
quantity	Specifies product quantity

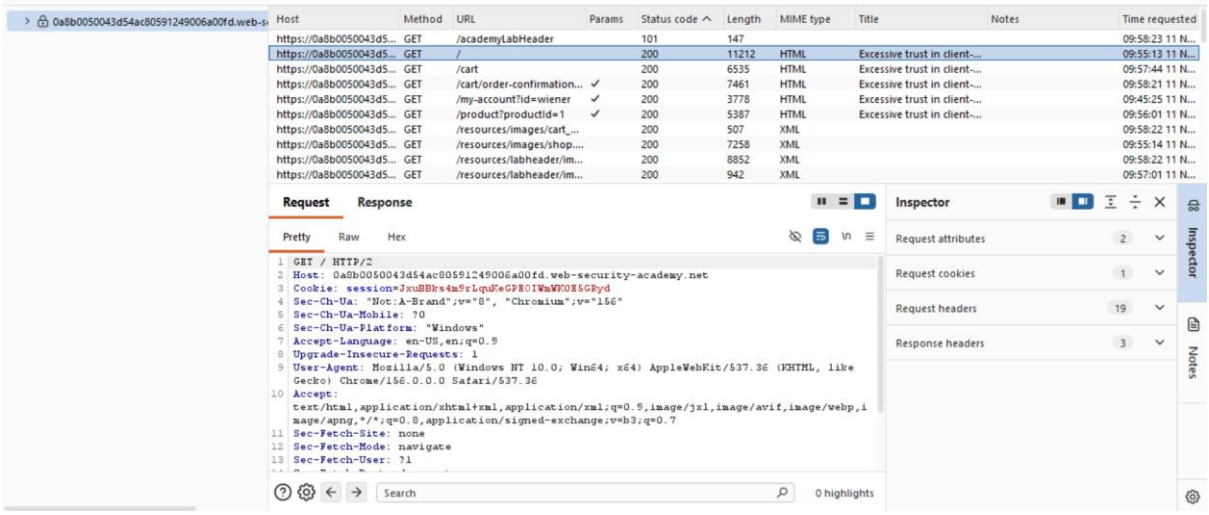
price	Price value submitted with cart information
redir	Redirect-related value
id	Identifies an account

Q7 — Practical Evidence [4 Marks]

Attach: Target Scope screenshot, HTTP History screenshot, Site Map screenshot, Application Map diagram. Explain the mapping process.



#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title	Notes	TLS	Cookies	IP	Time
39	https://0a8b0050043d54ac8...	GET	/academyLabHeader			101	147					✓		79.125.84.16	09:45:
40	https://0a8b0050043d54ac8...	POST	/cart	✓		302	100					✓		79.125.84.16	09:45:
41	https://0a8b0050043d54ac8...	GET	/product?productId=1	✓		200	5387	HTML		Excessive trust in clie...		✓		79.125.84.16	09:45:
42	https://0a8b0050043d54ac8...	GET	/academyLabHeader			101	147					✓		79.125.84.16	09:45:
43	https://0a8b0050043d54ac8...	GET	/product?productId=1	✓		200	5387	HTML		Excessive trust in clie...		✓		79.125.84.16	09:53:
52	https://0a8b0050043d54ac8...	GET	/academyLabHeader			101	147					✓		79.125.84.16	09:53:
54	https://0a8b0050043d54ac8...	GET	/product?productId=1	✓		200	5387	HTML		Excessive trust in clie...		✓		79.125.84.16	09:53:
56	https://0a8b0050043d54ac8...	GET	/academyLabHeader			101	147					✓		79.125.84.16	09:53:
57	https://0a8b0050043d54ac8...	GET	/product?productId=1	✓		200	5387	HTML		Excessive trust in clie...		✓		79.125.84.16	09:55:



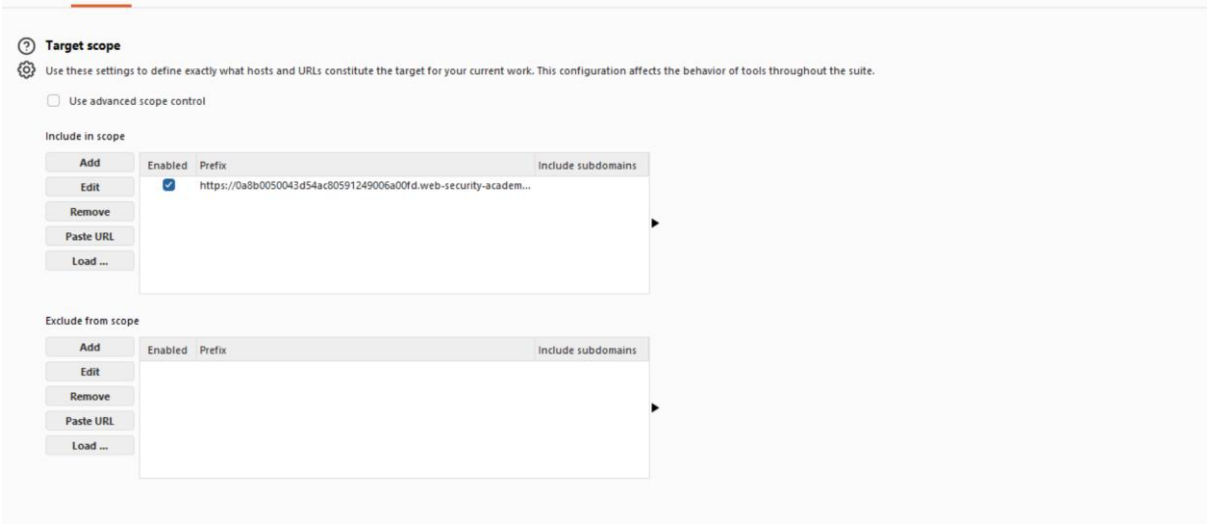
Host	Method	URL	Params	Status code	Length	MIME type	Title	Notes	Time requested
https://0a8b0050043d5...	GET	/academyLabHeader		101	147				09:58:23 11 N...
https://0a8b0050043d5...	GET	/		200	11212	HTML	Excessive trust in client-...		09:55:13 11 N...
https://0a8b0050043d5...	GET	/cart		200	6535	HTML	Excessive trust in client-...		09:57:44 11 N...
https://0a8b0050043d5...	GET	/cart/order-confirmation...	✓	200	7461	HTML	Excessive trust in client-...		09:58:21 11 N...
https://0a8b0050043d5...	GET	/my-account?id=wiener	✓	200	3778	HTML	Excessive trust in client-...		09:45:25 11 N...
https://0a8b0050043d5...	GET	/product?productId=1	✓	200	5387	HTML	Excessive trust in client-...		09:56:01 11 N...
https://0a8b0050043d5...	GET	/resources/images/cart_...		200	507	XML			09:58:22 11 N...
https://0a8b0050043d5...	GET	/resources/images/shop....		200	7258	XML			09:55:14 11 N...
https://0a8b0050043d5...	GET	/resources/labheader/im...		200	8852	XML			09:58:22 11 N...
https://0a8b0050043d5...	GET	/resources/labheader/im...		200	942	XML			09:57:01 11 N...

Request

```
1  GET / HTTP/2
2  Host: 0a8b0050043d54ac80591249006a00fd.web-security-academy.net
3  Cookie: session=JxuBBks4mSrLquKeGPEOIWmWKOE5GPyd
4  Sec-Ch-Ua: "Not:A-Brand";v="8", "Chromium";v="156"
5  Sec-Ch-Ua-Mobile: ?0
6  Sec-Ch-Ua-Platform: "Windows"
7  Accept-Language: en-US,en;q=0.9
8  Upgrade-Insecure-Requests: 1
9  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
   Gecko) Chrome/156.0.0.0 Safari/537.36
10 Accept:
   text/html,application/xhtml+xml,application/xml;q=0.9,image/jxl,image/avif,image/webp,i
   mage/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
11 Sec-Fetch-Site: none
12 Sec-Fetch-Mode: navigate
13 Sec-Fetch-User: ?1
```

Inspector

Request attributes 2
Request cookies 1
Request headers 19
Response headers 3



Target scope

Use these settings to define exactly what hosts and URLs constitute the target for your current work. This configuration affects the behavior of tools throughout the suite.

Use advanced scope control

Include in scope

Add | Edit | Remove | Paste URL | Load ...

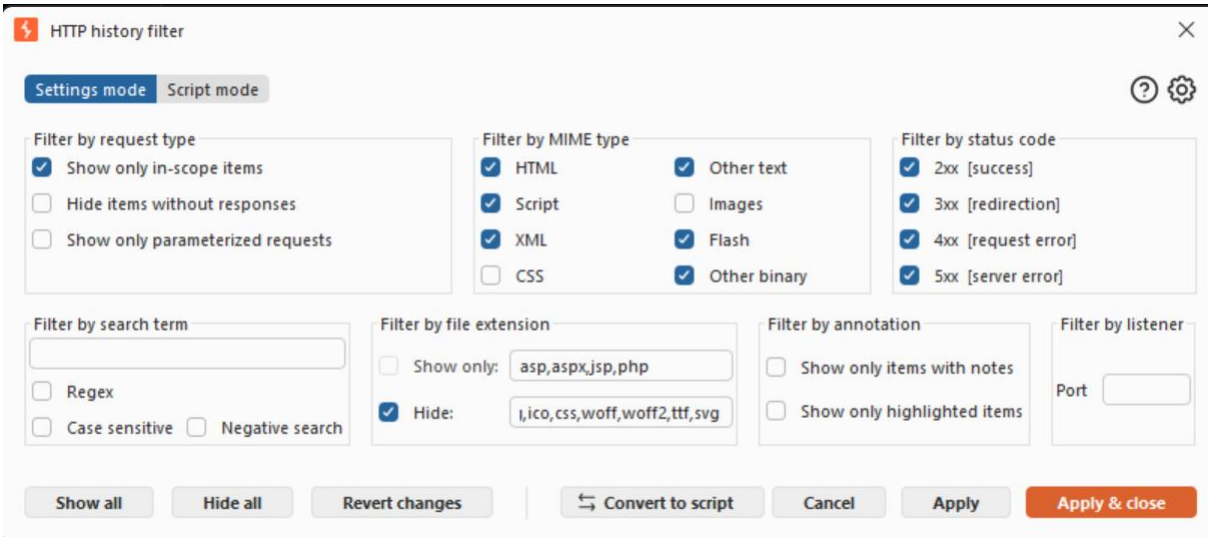
Enabled	Prefix	Include subdomains
✓	https://0a8b0050043d54ac80591249006a00fd.web-security-academ...	

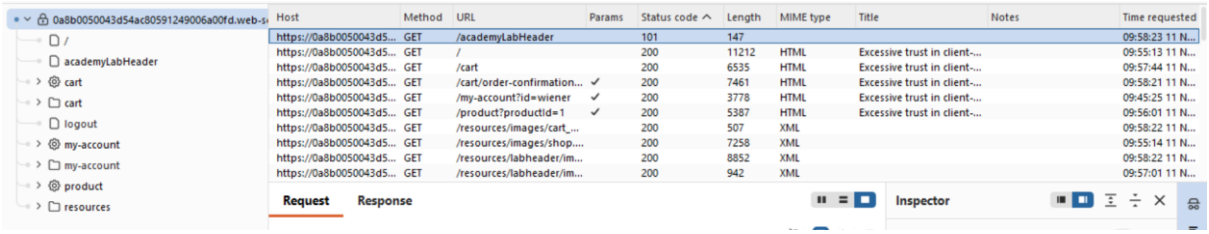
Exclude from scope

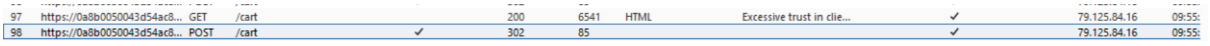
Add | Edit | Remove | Paste URL | Load ...

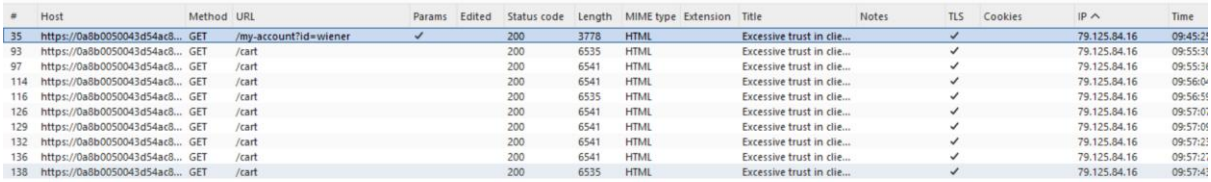
Enabled	Prefix	Include subdomains

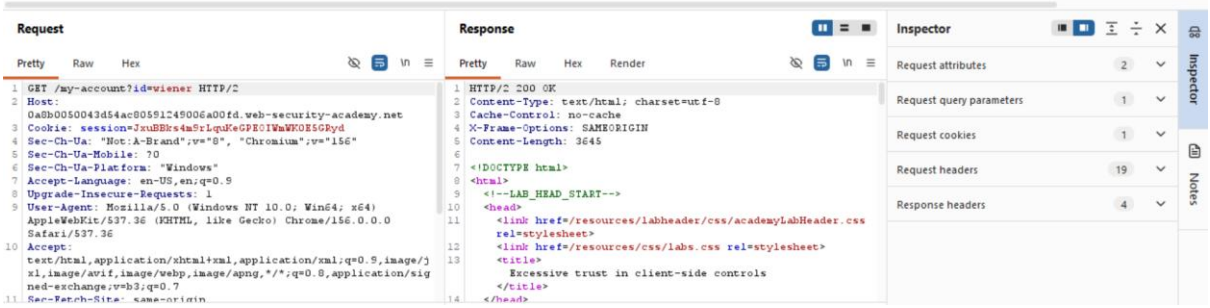
Day38_ApplicationMapping



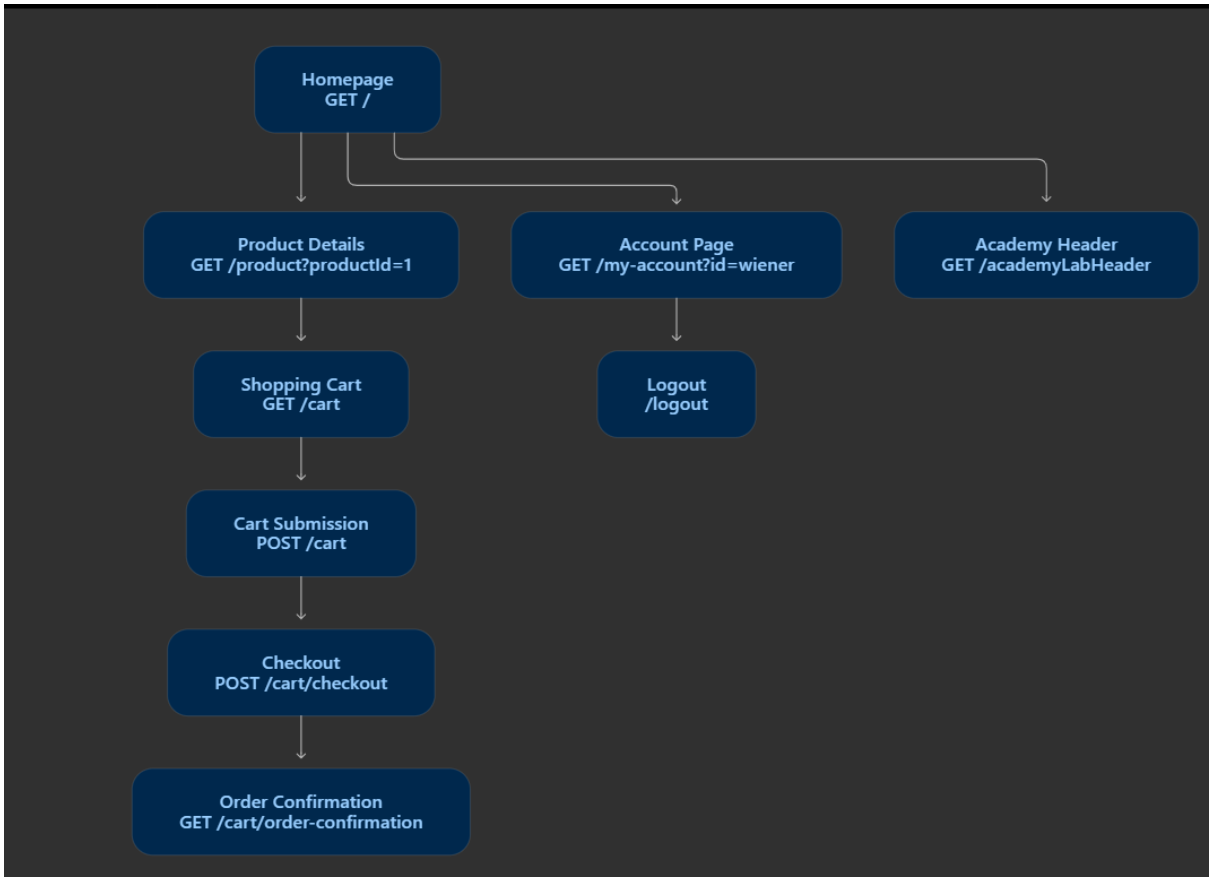








Day38_ApplicationMapping



Q8 — Professional Methodology [3 Marks]

Explain why a tester should understand an application before attempting deeper vulnerability testing.

1. Understand functionality: Mapping helps identify the application's features, endpoints and normal user workflows.
2. Identify the attack surface: It reveals input points, authentication areas and important application functions that may require further review.
3. Avoid unnecessary risks: Understanding the application and its authorized scope helps prevent accidental testing of unrelated systems and reduces disruption.